# Faida — Data Protection Overview

How Faida handles personal data, written against Kenya's Data Protection Act, 2019. This describes what the code does today. It is not legal advice — have it reviewed before relying on it for registration, a DPIA, or funder due diligence.

## What we collect and why

| Data | When | Purpose | Sensitive? |
|---|---|---|---|
| WhatsApp number | Every message | Reply to the user | Stored only as a salted SHA-256 hash, except for reminder opt-ins (encrypted, below) |
| Language, age, gender, county, employment status | Onboarding | Match the user to benefits | Personal |
| Disability status | Onboarding | Match disability-specific programmes | Sensitive (health) — covered by explicit consent |
| Name, ID number, phone, email, KRA PIN, bank / M-Pesa numbers, registration numbers | Only if the user fills an application form | Prepare a pre-filled application document for the user | Personal / financial |
| Messages sent in CHAT | Only if the user uses the AI assistant | Generate answers | May contain anything the user types |
| Feedback rating and comment | Only if the user sends FEEDBACK | Improve the service | Personal |

## Consent

- Before any personal question, users see a privacy notice (English or Kiswahili) and must reply **1** to agree. Declining erases what was stored.
- Consent is recorded with a version number and timestamp. Users who started before the notice existed are asked once on their next message. Raising `CONSENT_VERSION` in `faida-export/src/lib/privacy.js` asks everyone again.
- The notice discloses that CHAT messages and the profile are sent to the AI provider.

## User rights

| Right | How |
|---|---|
| Be informed | Privacy notice at onboarding; PRIVACY command at any time |
| Erasure | DELETE MY DATA (confirm with YES) deletes the user's users row, which cascades to sessions, applications and application_fields; analytics events keep no link to the user |
| Withdraw reminder consent | REMINDERS OFF deletes the stored contact |
| Access / correction | Not self-service yet — handle requests via PRIVACY_CONTACT. RESTART lets users re-enter their profile |

## Where data is stored and who processes it

| Processor | What | Notes |
|---|---|---|
| Supabase | Sessions, users, applications, analytics | Note the project's region; if outside Kenya, document the cross-border transfer safeguards |
| OpenAI or Anthropic | CHAT messages and profile summary | Outside Kenya — cross-border transfer; review each provider's data-processing terms and retention |
| WhatsApp (Meta) | Message transport | Currently via an unofficial client (Baileys); moving to the WhatsApp Business Platform is recommended |
| Bot host (currently a local PC; previously Railway) | Logs, temporary PDFs, WhatsApp session keys (.auth) | Logs mask ID/phone numbers; PDFs are deleted after sending |
| Vercel | Admin dashboard (no personal data stored there) | Dashboard reads Supabase server-side; admin login required |

## Security measures in the code

- Users are identified by a salted hash of their number (`FAIDA_HASH_SALT`).
- ID, KRA, bank, M-Pesa and similar form fields are encrypted with AES-256-GCM (`FAIDA_ENCRYPTION_KEY`) while an application is in progress. Without the key they are never written to the database.
- After an application is completed, its identity and financial fields are stored only as `[redacted]`; the dashboard never sees them.
- Numbers and emails are masked in logs and in stored AI chat history.
- Reminder opt-ins: the WhatsApp number is stored encrypted and deleted on opt-out.
- Idle sessions are cleared from server memory after 30 minutes.
- The admin dashboard requires a password; the WhatsApp pairing page requires a token.
- Database access from the public (anon) key is blocked by row-level security.

## Open items for the organisation (not code)

1. **Controller identity and contact** — set `PRIVACY_CONTACT` and name the legal entity responsible for Faida in the notice.
2. **ODPC registration** — check whether Faida must register as a data controller/processor with the Office of the Data Protection Commissioner (likely, given sensitive data).
3. **DPIA** — a data protection impact assessment is expected for processing sensitive data at scale.
4. **Processor agreements** — data-processing terms with Supabase, the AI provider and any host; document cross-border transfers.
5. **Retention policy** — decide how long inactive profiles and completed-application records are kept; the code currently keeps them until the user deletes them.
6. **Breach procedure** — who is notified, and how quickly the Commissioner and affected users are informed.

7. **Notice review** — legal review of the notice wording, and a native-speaker check of the Kiswahili text.
8. **Key management** — store `FAIDA_HASH_SALT`, `FAIDA_ENCRYPTION_KEY` and Supabase keys in a password manager; losing the encryption key makes in-progress forms and reminder contacts unreadable.